

Kobayashi Maru — Rapport de détection

Phase 2 — Observateur / défenseur — KM-M1-CDC-E · 2026

État du document (17/09/2026). Les 23 règles locales (§4) sont écrites, déployées et chargées sans erreur sur la sonde `nsm` depuis le matin du 16/09/2026. Avant le début de la Phase 2 (16/09/2026, 13h00), elles ont été **auto-testées** volontairement depuis nos propres adresses pour vérifier qu'elles se déclenchent — voir §5. À partir de 13h00-14h00 le 16/09/2026, le volume et la nature du trafic changent nettement (pic à ~4 500 alertes/20 min, balayage massif multi-CVE, tentatives d'exploitation génériques) : c'est la fenêtre où démarre le trafic du **groupe attaquant réel**, détaillée en §6. Le rapport d'attaque communiqué par le groupe attaquant (G10, 16/09/2026) corrobore, de façon indépendante, la compromission réelle d'E2, E5, E7, E8 et E11 — voir §6a.

1 Contexte et rôle

CHAMP	VALEUR
Rôle	Observateur / défenseur — détection et documentation des attaques menées contre le SI MaisonVerte du groupe G04
Sonde	Suricata + EveBox sur <code>nsm</code> (<code>192.168.10.30</code>), pont L2 transparent entre le segment poste et <code>vu\ndb</code>
Complément	Stack ELK défensive (Elasticsearch/Kibana/Filebeat, zone <code>net-admin</code>), distincte du service vulnérable E7, lit les logs Docker JSON en lecture seule
Fenêtre d'observation	Phase 2 — Jour 3 (13h00-18h00) et Jour 4 (09h30-18h00)

2 Sources de détection

SOURCE	RÔLE	LIMITE
Suricata	Preuve réseau officielle	Voit le trafic qui traverse le pont L2 (dont le trafic N1 externe via NAT OPNsense), pas nécessairement les flux intra-hôte Docker (la plupart des pivots N2/N3)
EveBox	Consultation des alertes Suricata	Accessible depuis le pivot interne, <code>http://192.168.10.30:5636/</code>
ELK défensif	Logs Docker au format JSON, par conteneur	Distinct de E7 (vulnérable) ; Kibana publié en loopback uniquement (<code>127.0.0.1:5601</code> sur <code>vu\ndb</code>), tunnel SSH requis
Logs Docker	Traces applicatives par conteneur	Dépendent des images et des healthchecks fournis par Vulhub

Principe retenu : ELK ne remplace jamais Suricata, il en complète les angles morts Docker. Le fichier de règles locales est `/etc/suricata/rules/tp-local.rules` sur `nsm`, avec des SID locaux à partir de `9000001` ; une correspondance `SID → étape → alerte → preuve` est tenue à jour dans `documentation/05-detection.md`.

3 Couverture attendue par famille

FAMILLE	EXEMPLES À COUVRIR	PREUVE À AJOUTER
Reconnaissance	scans, vhosts, chemins sensibles	alerte EveBox + paquet/log

N1 (points d'entrée)	E2 nginx, E3 WordPress, E5 Tomcat	alerte par point d'entrée
Pivots internes	E7, E8, E14, E12, E6, E9	alerte ou log corrélé
DATA / SHOPS	E10, E11, E13	flux final + accès flag masqué
Canaries IA	AI - CANARY - * si déclenchés	alerte sans effet fonctionnel
Services sains	E4, E15, E16	logs montrant un accès normal, sans flag volontaire

4 Règles de détection produites

Déployées le 16/09/2026 sur `/etc/suricata/rules/tp-local.rules` (sonde `nsm`) : 23 règles locales ajoutées (SID 9000007 à 9000029) au-dessus des 6 règles socle fournies par la plateforme (SID 9000001-9000006, non modifiées, listées §4a). Validation `suricata -T -c /etc/suricata/suricata.yaml` : 0 erreur. Rechargement (`systemctl restart suricata`) : 52613 règles chargées au total, 0 échec. Sauvegarde de l'ancien fichier : `/etc/suricata/rules/tp-local.rules.bak-20260916`. Copie versionnée : `deploiement/80-detection/tp-local.rules`.

4a. Socle plateforme (non modifié)

SID	MESSAGE	DÉCLENCHEUR
9000001	ICMP echo request vers le segment protégé	ping vers <code>vulnldb</code> /segment protégé
9000002	Marqueur de test (URI <code>/tp-suricata-test</code>)	requête HTTP de test
9000003	Connexion MySQL/MariaDB vers le segment protégé	connexion TCP/3306
9000004	Connexion Redis (sans authentification) vers le segment protégé	connexion TCP/6379
9000005	Injection SQL probable (UNION SELECT dans l'URI)	motif générique dans l'URI
9000006	Balayage de ports probable (SYN vers >15 ports en 10s)	scan TCP

4b. Reconnaissance

SID	MESSAGE	DÉCLENCHEUR
9000007	User-agent <code>sqlmap</code>	en-tête <code>User-Agent</code> HTTP
9000008	User-agent <code>Nikto</code>	en-tête <code>User-Agent</code> HTTP
9000009	Outil de brute-force de répertoires (gobuster/dirbuster/ffuf/wfuzz)	en-tête <code>User-Agent</code> HTTP

4c. N1 — points d'entrée (E2, E3, E5)

SID	SERVICE	MESSAGE	DÉCLENCHEUR
9000010	E2	nginx alias path traversal (<code>/files../</code>)	URI HTTP
9000011	E3	WordPress pwnscriptum, injection de commande via en-tête Host (<code>\${run{}</code>)	URI <code>/wp-login.php</code> + en-tête Host
9000012	E5	Tomcat PUT JSP (CVE-2017-12615)	méthode PUT + URI se terminant par <code>.jsp</code>

4d. Pivots internes (E6, E7, E8, E9, E12, E14)

SID	SERVICE	MESSAGE	DÉCLENCHEUR
9000013	E7	Elasticsearch RCE via script groovy (CVE-2015-1427)	URI <code>_search</code> + corps <code>"lang":"groovy"</code>
9000014	E8	Redis SLAVEOF/REPLICAOF (prise de contrôle rogue master)	commande Redis <code>SLAVEOF</code>
9000015	E8	Redis MODULE LOAD	commandes Redis <code>MODULE</code> + <code>LOAD</code>
9000016	E14	Jenkins — téléchargement <code>jenkins-cli.jar</code> (reconnaissance CVE-2024-23897)	URI <code>/jnlpJars/jenkins-cli.jar</code>
9000017	E14	Jenkins CLI — lecture de fichier arbitraire (<code>@/chemin</code>)	URI <code>/cli</code> + corps contenant <code>@/</code>
9000018	E12	XXL-JOB executor — RCE <code>GLUE_SHELL</code> non authentifiée	URI <code>/run</code> (port 9999) + corps <code>GLUE_SHELL</code>

9000019	E11	mongo-express /checkValid RCE (CVE-2019-10758)	URI /checkValid + corps constructor.constructor
9000020	E6	OFBiz ProgramExport — contournement d'authentification (CVE-2023-51467)	URI /webtools/control/ProgramExport + USERNAME=
9000021	E9	Samba — écriture d'un objet ,so sur le partage (préalable CVE-2017-7494)	contenu TCP/445
9000022	E13	Struts2 S2-045 — OGNL dans l'en-tête Content-Type	en-têtes HTTP : multipart/form-data + %{'

4e. DATA / SHOPS — objectifs finaux

SID	SERVICE	MESSAGE	DÉCLENCHEUR
9000023	E10	PostgreSQL COPY FROM PROGRAM (CVE-2019-9193)	contenu TCP/5432 : COPY + PROGRAM

4f. Leurres / canary IA

SID	MESSAGE	DÉCLENCHEUR
9000024	Jeton de prompt-injection IA utilisé (AI - CANARY - *)	contenu HTTP AI - CANARY -

4g. Violation d'isolation

SID	MESSAGE	DÉCLENCHEUR
9000025	Accès direct poste → port interne normalement non joignable	source 192.168.10.10 (poste) vers 5432/27017/6379/9200/445/9999/8443

4h. Visibilité N1 fiable — SNI TLS (fonctionne malgré le chiffrement)

SID	SERVICE	MESSAGE	STATUT
9000026	E2	SNI cache.maisonverte.fr	Auto-test OK 16/09 10:58:48 ; ré-observée en Phase 2 (§6)
9000027	E3	SNI shop.maisonverte.fr	Auto-test OK 16/09 10:58:48 ; ré-observée en Phase 2 (§6), signature la plus fréquente (3 562 hits)
9000028	E5	SNI vendeurs.maisonverte.fr	Auto-test OK 16/09 10:58:48 ; ré-observée en Phase 2 (§6)
9000029	E4 (sain)	SNI api.maisonverte.fr	Non prioritaire en auto-test, mais également déclenchée en Phase 2 (service sain scanné par l'attaquant comme les autres)

5 Validation des règles pendant le build (auto-test, avant 13h00 le 16/09)

Portée de cette section. Ce qui suit décrit des tests menés par nous-mêmes contre notre propre infrastructure, **avant le début de la Phase 2** (16/09/2026, avant 13h00), pour vérifier que les règles se déclenchent. Les attaques réellement détectées ensuite, une fois la Phase 2 lancée, sont documentées en §6.

- E2/E3/E5 sont publiés en TLS (443, nginx par défaut = cipher ECDHE, forward secrecy). Le test réalisé le 16/09/2026 au matin a montré que :
- Les **signatures de contenu HTTP** (traversal /files../ , user-agent sqlmap , en-tête canary AI-CANARY-*, etc.) **ne se déclenchent pas** sur ce trafic : Suricata ne peut pas inspecter un contenu chiffré sans les clés de session, et la capture passive de clé RSA ne fonctionne pas avec ECDHE/TLS 1.3. Ces règles restent dans le fichier (elles documentent la logique de détection attendue et s'activeraient sur un flux en clair) mais **ne doivent pas être présentées comme preuve réseau** pour les services servis derrière E2.
 - Les **règles SNI TLS** (9000026-9000029) **se sont bien déclenchées** : test à 10:58:48 le 16/09/2026, alertes MV N1 TLS SNI shop.maisonverte.fr , vendeurs.maisonverte.fr et cache.maisonverte.fr vues dans fast.log vers 192.168.10.50:443 . Ça a validé que la détection réseau fonctionnerait aussi pour le trafic N1 du groupe attaquant réel — confirmé en §6.
 - **Preuve applicative** (contenu réel de la requête/exploit) : à chercher dans les logs des conteneurs via ELK/ Filebeat (ex. access log nginx d'E2), qui voient le trafic en clair après déchiffrement côté conteneur — pas dans Suricata pour ce qui passe par E2.

La sonde nsm est un pont L2 transparent entre le segment « poste » et vulndb : elle voit tout le trafic qui atteint vulndb (y compris le trafic externe N1 via le NAT OPNsense), mais **pas** le trafic qui reste interne aux réseaux

Docker de vulndb (la plupart des pivots N2/N3 après E2/E3/E5). ELK/Filebeat complète la visibilité que Suricata n'a pas sur ces flux.

		1	2026-09-16 12:18:37 21 hours ago	S: 192.168.10.10 D: 192.168.10.30	ET SCAN Potential SSH Scan	Archive
		1	2026-09-16 12:18:37 21 hours ago	S: 192.168.10.10 D: 192.168.10.30	ET SCAN Potential SSH Scan OUTBOUND	Archive
		2	2026-09-16 12:12:12 21 hours ago	S: 192.168.10.30 D: 192.168.10.10	GPL ICMP PING *NIX	Archive
		2	2026-09-16 12:12:07 21 hours ago	S: 192.168.10.30 D: 192.168.10.50	GPL ICMP PING *NIX	Archive
		1	2026-09-16 12:12:06 21 hours ago	S: 192.168.10.30 D: 192.168.10.50	TP LOCAL ICMP echo request vers le segment protege	Archive
		1	2026-09-16 12:00:20 a day ago	S: 192.168.10.10 D: 192.168.10.30	TP LOCAL balayage de ports probable (SYN vers >15 ports en 10s)	Archive
		14	2026-09-16 11:59:55 a day ago	S: 10.200.0.60 D: 192.168.10.50	MV N1 TLS SNI cache.maisonverte.fr (E2, reverse proxy) app_protocols sni.cache.maisonverte.fr	Archive

image.png – 16/09/2026 11:59:55-12:18:37 (avant Phase 2) – SSH scan + ICMP + balayage de ports, trafic d'auto-test. Capturé par : Thibault Foulon.

		30	2026-09-16 13:15:33 20 hours ago	S: 192.168.10.10 D: 192.168.10.50	GPL ICMP PING *NIX	Archive
		5	2026-09-16 13:15:33 20 hours ago	S: 192.168.10.10 D: 192.168.10.30	GPL ICMP PING *NIX	Archive
		2	2026-09-16 13:15:33 20 hours ago	S: 192.168.10.10 D: 192.168.10.30	TP LOCAL ICMP echo request vers le segment protege	Archive
		2	2026-09-16 12:29:08 21 hours ago	S: 10.200.0.66 D: 192.168.10.50	MV N1 TLS SNI cache.maisonverte.fr (E2, reverse proxy) app_protocols sni.cache.maisonverte.fr	Archive
		2	2026-09-16 12:28:59 21 hours ago	S: 10.200.0.66 D: 192.168.10.50	MV N1 TLS SNI vendeurs.maisonverte.fr (E5, Tomcat) app_protocols sni.vendeurs.maisonverte.fr	Archive
		2	2026-09-16 12:28:43 21 hours ago	S: 10.200.0.66 D: 192.168.10.50	MV TLS SNI api.maisonverte.fr (E4, sain) app_protocols sni.api.maisonverte.fr	Archive
		40	2026-09-16 12:28:27 21 hours ago	S: 10.200.0.67 D: 192.168.10.50	MV N1 TLS SNI shop.maisonverte.fr (E3, WordPress) app_protocols sni.shop.maisonverte.fr	Archive
		12	2026-09-16 12:27:29 21 hours ago	S: 10.200.0.66 D: 192.168.10.50	MV N1 TLS SNI shop.maisonverte.fr (E3, WordPress) app_protocols sni.shop.maisonverte.fr	Archive
		2	2026-09-16 12:27:28 21 hours ago	S: 10.200.0.66 D: 192.168.10.50	TP LOCAL balayage de ports probable (SYN vers >15 ports en 10s)	Archive
		69	2026-09-16 12:21:15 21 hours ago	S: 192.168.10.10 D: 192.168.10.30	ET HUNTING curl User-Agent to Dotted Quad app_protocols hostname:127.0.0.1	Archive
		2	2026-09-16 12:20:54 21 hours ago	S: 192.168.10.10 D: 192.168.10.30	MV GLOBAL exploit payload marker dans corps HTTP app_protocols hostname:127.0.0.1	Archive
		3	2026-09-16 12:20:54 21 hours ago	S: 192.168.10.10 D: 192.168.10.30	ET INFO POSSIBLE Web Crawl using Curl app_protocols hostname:127.0.0.1	Archive
		2	2026-09-16 12:20:54 21 hours ago	S: 192.168.10.10 D: 192.168.10.30	MV GLOBAL suspicious HTTP method PUT DELETE PATCH app_protocols hostname:127.0.0.1	Archive
		2	2026-09-16 12:20:54 21 hours ago	S: 192.168.10.10 D: 192.168.10.30	MV GLOBAL traversal path dans URI HTTP app_protocols hostname:127.0.0.1	Archive
		2	2026-09-16 12:20:54 21 hours ago	S: 192.168.10.10 D: 192.168.10.30	ET WEB_SERVER /etc/passwd Detected in URI app_protocols hostname:127.0.0.1	Archive
		2	2026-09-16 12:20:01 21 hours ago	S: 192.168.10.10 D: 192.168.10.30	TP LOCAL marqueur de test (URI /tp-suricata-test) app_protocols hostname:127.0.0.1	Archive

1.png – 16/09/2026 12:20:01-13:15:33 – fin de l'auto-test des règles N1/reconnaissance juste avant l'ouverture de la Phase 2 (13h00). Capturé par : Thibault Foulon.

6 Attaques détectées en Phase 2 (groupe attaquant réel)

À partir de 13h00 le 16/09/2026 (ouverture de la Phase 2), le trafic reçu sur nsm change de nature par rapport aux auto-tests du §5 : montée en volume, diversité des sources, et signatures typiques d'un scan de vulnérabilités puis d'essais d'exploitation générique — cohérent avec un groupe de 6 attaquants connectés chacun depuis sa propre adresse VPN (10.200.0.2 , .4 , .5 , .6 , .7 ...). Repères EveBox agrégés (§ vue d'ensemble ci-dessous) : 10 095 alertes / 58 signatures sur la fenêtre observée, pic à ~2 100 puis ~4 500 alertes entre 14h30 et 14h49.

HORODATAGE (16/09/2026, SAUF MENTION)	SID / RÈGLE	NATURE	SOURCE
13:15 – 13:41	MV ISOLATION (9000025) ; ET SCAN inbound MySQL/PostgreSQL ; TP LOCAL balayage de ports (9000006) ; ET INFO GIOP/RMI Outbound ; premiers SNI E2/E5 (9000026/28)	Ouverture immédiate de l'attaque : violation d'isolement (accès direct poste → 3306/5432), balayage de ports, reconnaissance de services Java (RMI/ GIOP — probablement en quête d'E7/ E12/E14), premiers hits N1	192.168.10.10 , 10.200.0.66/67
13:42 – 14:47	ET SCAN Nmap Scripting Engine ; ET/GPL EXPLOIT et WEB_SERVER (Cisco IOS exec, ZyXEL config, OrangeHRM LFI, DD-WRT disclosure, .htpasswd/.htaccess, / etc/passwd in URI)	Montée en charge : scanner multi-CVE générique (type Nmap --script vuln) contre la façade N1	10.200.0.6
14:47 – 14:54	ET SCAN Nmap Scripting Engine (4 422 hits — signature la plus fréquente de toute la fenêtre)	Pic de reconnaissance automatisée	10.200.0.6
14:56 – 17:36	ET WEB_SERVER PHP tags/System Command in HTTP POST ;	Tentatives d'exploitation applicative (injection PHP) puis ciblage répété des	10.200.0.2 , .4 , .5 , .6 ,

	CVE-2016-10033 PHPMailer RCE Attempt ; puis SNI répétés 9000026/27/28/29 (E2/E3/E5/E4)	3 N1 + E4 ; pic à 2 006 hits sur le SNI shop.maisonverte.fr à 16:40	
17:36 – 18:19	ET SCAN Potential SSH Scan / SSH Scan OUTBOUND ; MV GLOBAL sensitive service access	Probable pivot après accès initial : sondage de services internes normalement non joignables depuis la position « poste »	192.168.10.10
17/09/2026 09:39	MV GLOBAL sensitive service access	Activité en cours ce matin (Jour 4) — à requalifier/compléter au fil de la journée jusqu'à 18h00	192.168.10.10

4	2026-09-16 13:41:26 20 hours ago	S: 192.168.10.50 D: 10.85.4.10	ET INFO GIOP/IOP Request Outbound	Archive
10	2026-09-16 13:41:21 20 hours ago	S: 10.85.4.10 D: 192.168.10.50	SURICATA HTTP unable to match response to request app_proto:http	Archive
2	2026-09-16 13:41:16 20 hours ago	S: 192.168.10.50 D: 10.85.4.10	ET INFO RMI Request Outbound	Archive
2	2026-09-16 13:40:33 20 hours ago	S: 10.85.4.10 D: 192.168.10.50	ET INFO TLS Handshake Failure app_proto:tls	Archive
178	2026-09-16 13:36:11 20 hours ago	S: 10.200.0.67 D: 192.168.10.50	MV N1 TLS SNI vendeurs.maisonverte.fr (E5, Tomcat) app_proto:tls snicvendeurs.maisonverte.fr	Archive
1	2026-09-16 13:35:45 20 hours ago	S: 10.200.0.67 D: 192.168.10.50	TP LOCAL balayage de ports probable (SYN vers >15 ports en 10s)	Archive
2	2026-09-16 13:34:11 20 hours ago	S: 10.200.0.6 D: 192.168.10.50	SURICATA HTTP invalid content length field in request app_proto:http hostname:*.maisonverte.fr	Archive
2	2026-09-16 13:34:11 20 hours ago	S: 10.200.0.6 D: 192.168.10.50	SURICATA HTTP Host header invalid app_proto:http hostname:*.maisonverte.fr	Archive
18	2026-09-16 13:24:40 20 hours ago	S: 10.200.0.67 D: 192.168.10.50	MV N1 TLS SNI cache.maisonverte.fr (E2, reverse proxy) app_proto:tls snicache.maisonverte.fr	Archive
6	2026-09-16 13:15:42 20 hours ago	S: 192.168.10.10 D: 192.168.10.50	MV ISOLATION acces direct poste vers un port interne normalement non joignable	Archive
2	2026-09-16 13:15:42 20 hours ago	S: 192.168.10.10 D: 192.168.10.50	ET SCAN Suspicious inbound to MySQL port 3306	Archive
1	2026-09-16 13:15:42 20 hours ago	S: 192.168.10.10 D: 192.168.10.30	ET SCAN Suspicious inbound to PostgreSQL port 5432	Archive
1	2026-09-16 13:15:42 20 hours ago	S: 192.168.10.10 D: 192.168.10.50	TP LOCAL balayage de ports probable (SYN vers >15 ports en 10s)	Archive
2	2026-09-16 13:15:42 20 hours ago	S: 192.168.10.10 D: 192.168.10.50	ET SCAN Suspicious inbound to PostgreSQL port 5432	Archive
3	2026-09-16 13:15:42 20 hours ago	S: 192.168.10.10 D: 192.168.10.30	MV ISOLATION acces direct poste vers un port interne normalement non joignable	Archive
1	2026-09-16 13:15:42 20 hours ago	S: 192.168.10.10 D: 192.168.10.30	ET SCAN Suspicious inbound to MySQL port 3306	Archive

2.png – 16/09/2026 13:15:42-13:41:26 – ouverture de l'attaque : isolation, scan, reconnaissance Java, premiers SNI. Capturé par : Thibault Foulon.

2	2026-09-16 14:47:37 19 hours ago	S: 10.200.0.6 D: 192.168.10.50	GPL WEB_SERVER service.pwd app_proto:http hostname:maisonverte.fr	Archive
2	2026-09-16 14:47:36 19 hours ago	S: 10.200.0.6 D: 192.168.10.50	GPL WEB_SERVER service.cnf access app_proto:http hostname:maisonverte.fr	Archive
2	2026-09-16 14:47:35 19 hours ago	S: 10.200.0.6 D: 192.168.10.50	GPL WEB_SERVER authors.pwd access app_proto:http hostname:maisonverte.fr	Archive
2	2026-09-16 14:47:35 19 hours ago	S: 10.200.0.6 D: 192.168.10.50	GPL EXPLOIT administrators.pwd access app_proto:http hostname:maisonverte.fr	Archive
2	2026-09-16 14:47:35 19 hours ago	S: 10.200.0.6 D: 192.168.10.50	GPL EXPLOIT fpcount access app_proto:http hostname:maisonverte.fr	Archive
2	2026-09-16 14:47:34 19 hours ago	S: 10.200.0.6 D: 192.168.10.50	GPL WEB_SERVER author.exe access app_proto:http hostname:maisonverte.fr	Archive
2	2026-09-16 14:46:37 19 hours ago	S: 10.200.0.6 D: 192.168.10.50	ET WEB_SERVER Cisco IOS HTTP Server Exec Command Execution Attempt app_proto:http hostname:maisonverte.fr	Archive
2	2026-09-16 14:46:35 19 hours ago	S: 10.200.0.6 D: 192.168.10.50	ET WEB_SERVER WEB-PHP phpinfo access app_proto:http hostname:maisonverte.fr	Archive
2	2026-09-16 14:46:28 19 hours ago	S: 10.200.0.6 D: 192.168.10.50	GPL EXPLOIT liissamples access app_proto:http hostname:maisonverte.fr	Archive
8	2026-09-16 14:43:58 19 hours ago	S: 10.200.0.4 D: 192.168.10.50	TP LOCAL balayage de ports probable (SYN vers >15 ports en 10s)	Archive
2	2026-09-16 13:59:57 20 hours ago	S: 10.200.0.5 D: 192.168.10.50	ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Engine) app_proto:http hostname:10.85.4.10	Archive
8	2026-09-16 13:43:08 20 hours ago	S: 192.168.10.50 D: 10.85.4.10	ET SCAN Possible Nmap User-Agent Observed app_proto:http hostname:10.85.4.10	Archive
14	2026-09-16 13:43:08 20 hours ago	S: 192.168.10.50 D: 10.85.4.10	SURICATA Applayer Detect protocol only one direction app_proto:http	Archive
8	2026-09-16 13:43:08 20 hours ago	S: 192.168.10.50 D: 10.85.4.10	SURICATA Applayer Mismatch protocol both directions app_proto:tls	Archive
4	2026-09-16 13:42:30 20 hours ago	S: 192.168.10.50 D: 10.85.4.10	ET INFO Outbound MSSQL Connection to Non-Standard Port - Likely Malware app_proto:http	Archive
8	2026-09-16 13:42:30 20 hours ago	S: 192.168.10.50 D: 10.85.4.10	SURICATA HTTP Request line incomplete app_proto:http	Archive

3.png – 16/09/2026 13:42:30-14:47:37 – montée en charge, scan multi-CVE générique. Capturé par : Thibault Foulon.

☆ 16	2026-09-16 14:54:11 19 hours ago	S: 192.168.10.10 D: 192.168.10.50	SURICATA Applayer Mismatch protocol both directions	app_proto:tls	Archive
☆ 34	2026-09-16 14:54:10 19 hours ago	S: 192.168.10.30 D: 192.168.10.10	SURICATA Applayer Mismatch protocol both directions	app_proto:tls	Archive
4422	2026-09-16 14:49:46 19 hours ago	S: 10.200.0.6 D: 192.168.10.50	ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Engine)	app_proto:http hostname:maisonverte.fr	Archive
☆ 2	2026-09-16 14:49:05 19 hours ago	S: 10.200.0.6 D: 192.168.10.50	GPL WEB_SERVER Oracle Java Process Manager access	app_proto:http hostname:maisonverte.fr	Archive
☆ 2	2026-09-16 14:48:49 19 hours ago	S: 10.200.0.6 D: 192.168.10.50	GPL WEB_SERVER iisadmin access	app_proto:http hostname:maisonverte.fr	Archive
☆ 2	2026-09-16 14:47:41 19 hours ago	S: 10.200.0.6 D: 192.168.10.50	ET EXPLOIT Cisco RV320/RV325 Config Disclosure Attempt Inbound (CVE-2019-1653)	app_proto:http hostname:maisonverte.fr	Archive
☆ 6	2026-09-16 14:47:41 19 hours ago	S: 10.200.0.6 D: 192.168.10.50	ET WEB_SERVER /etc/passwd Detected in URI	app_proto:http hostname:maisonverte.fr	Archive
☆ 2	2026-09-16 14:47:40 19 hours ago	S: 10.200.0.6 D: 192.168.10.50	ET EXPLOIT Possible ZyXELs ZynOS Configuration Download Attempt (Contains Passwords)	app_proto:http hostname:maisonverte.fr	Archive
☆ 8	2026-09-16 14:47:40 19 hours ago	S: 10.200.0.6 D: 192.168.10.50	MV GLOBAL traversal path dans URI HTTP	app_proto:http hostname:maisonverte.fr	Archive
☆ 2	2026-09-16 14:47:40 19 hours ago	S: 10.200.0.6 D: 192.168.10.50	ET WEB_SPECIFIC_APPS OrangeHRM path Parameter Local File Inclusion Attempt	app_proto:http hostname:maisonverte.fr	Archive
☆ 2	2026-09-16 14:47:39 19 hours ago	S: 10.200.0.6 D: 192.168.10.50	ET WEB_SERVER DD-WRT Information Disclosure Attempt	app_proto:http hostname:maisonverte.fr	Archive
☆ 4	2026-09-16 14:47:38 19 hours ago	S: 10.200.0.6 D: 192.168.10.50	GPL WEB_SERVER .htpasswd access	app_proto:http hostname:maisonverte.fr	Archive
☆ 4	2026-09-16 14:47:38 19 hours ago	S: 10.200.0.6 D: 192.168.10.50	GPL WEB_SERVER .htaccess access	app_proto:http hostname:maisonverte.fr	Archive
☆ 2	2026-09-16 14:47:38 19 hours ago	S: 10.200.0.6 D: 192.168.10.50	GPL WEB_SERVER writeto.cnf access	app_proto:http hostname:maisonverte.fr	Archive
☆ 20	2026-09-16 14:47:38 19 hours ago	S: 10.200.0.6 D: 192.168.10.50	GPL EXPLOIT .cnf access	app_proto:http hostname:maisonverte.fr	Archive
☆ 2	2026-09-16 14:47:37 19 hours ago	S: 10.200.0.6 D: 192.168.10.50	GPL WEB_SERVER services.cnf access	app_proto:http hostname:maisonverte.fr	Archive

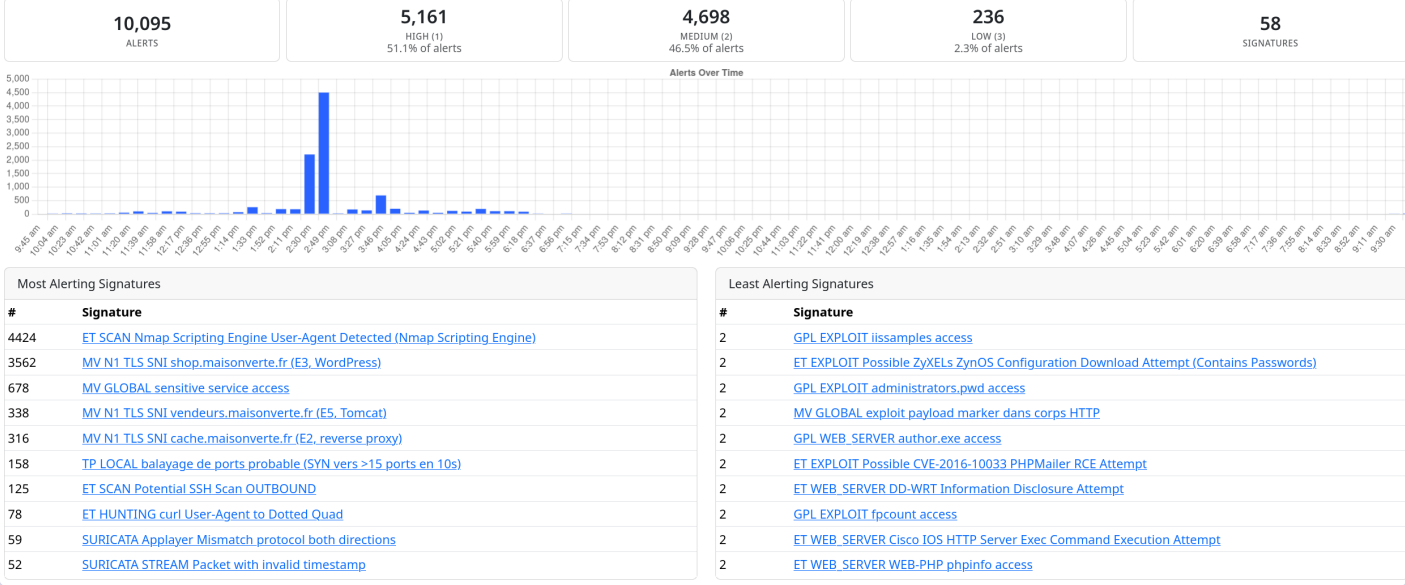
4.png – 16/09/2026 14:47:37-14:54:11 – pic de reconnaissance (4 422 hits Nmap Scripting Engine). Capturé par : Thibault Foulon.

☆ 28	2026-09-16 17:36:37 16 hours ago	S: 10.200.0.5 D: 192.168.10.50	MV TLS SNI api.maisonverte.fr (E4, sain)	app_proto:tls sni:api.maisonverte.fr	Archive
☆ 34	2026-09-16 17:36:22 16 hours ago	S: 10.200.0.4 D: 192.168.10.50	MV N1 TLS SNI vendeurs.maisonverte.fr (E5, Tomcat)	app_proto:tls sni:vendeurs.maisonverte.fr	Archive
☆ 312	2026-09-16 17:30:41 16 hours ago	S: 10.200.0.5 D: 192.168.10.50	MV N1 TLS SNI shop.maisonverte.fr (E3, WordPress)	app_proto:tls sni:shop.maisonverte.fr	Archive
☆ 4	2026-09-16 17:14:44 16 hours ago	S: 10.200.0.2 D: 192.168.10.50	TP LOCAL balayage de ports probable (SYN vers >15 ports en 10s)		Archive
☆ 2006	2026-09-16 16:40:36 17 hours ago	S: 10.200.0.4 D: 192.168.10.50	MV N1 TLS SNI shop.maisonverte.fr (E3, WordPress)	app_proto:tls sni:shop.maisonverte.fr	Archive
☆ 64	2026-09-16 16:16:50 17 hours ago	S: 10.200.0.7 D: 192.168.10.50	MV N1 TLS SNI shop.maisonverte.fr (E3, WordPress)	app_proto:tls sni:shop.maisonverte.fr	Archive
☆ 2	2026-09-16 16:14:59 17 hours ago	S: 10.200.0.7 D: 192.168.10.50	SURICATA STREAM Packet with invalid timestamp		Archive
☆ 4	2026-09-16 15:28:39 18 hours ago	S: 192.168.10.50 D: 10.85.4.10	ET HUNTING curl User-Agent to Dotted Quad	app_proto:http hostname:10.85.4.10	Archive
☆ 4	2026-09-16 15:28:39 18 hours ago	S: 192.168.10.50 D: 10.85.4.10	ET HUNTING Terse Request for .txt - Likely Hostile	app_proto:http hostname:10.85.4.10	Archive
☆ 4	2026-09-16 15:19:01 18 hours ago	S: 10.200.0.7 D: 192.168.10.50	MV N1 TLS SNI cache.maisonverte.fr (E2, reverse proxy)	app_proto:tls sni:cache.maisonverte.fr	Archive
☆ 2	2026-09-16 15:19:01 18 hours ago	S: 10.200.0.7 D: 192.168.10.50	TP LOCAL balayage de ports probable (SYN vers >15 ports en 10s)		Archive
☆ 4	2026-09-16 15:19:01 18 hours ago	S: 10.200.0.7 D: 192.168.10.50	MV N1 TLS SNI vendeurs.maisonverte.fr (E5, Tomcat)	app_proto:tls sni:vendeurs.maisonverte.fr	Archive
☆ 4	2026-09-16 15:19:01 18 hours ago	S: 10.200.0.7 D: 192.168.10.50	MV TLS SNI api.maisonverte.fr (E4, sain)	app_proto:tls sni:api.maisonverte.fr	Archive
☆ 2	2026-09-16 14:56:47 19 hours ago	S: 10.200.0.6 D: 192.168.10.50	ET WEB_SERVER PHP tags in HTTP POST	app_proto:http hostname:10.85.4.10	Archive
☆ 2	2026-09-16 14:56:47 19 hours ago	S: 10.200.0.6 D: 192.168.10.50	ET WEB_SERVER PHP System Command in HTTP POST	app_proto:http hostname:10.85.4.10	Archive
☆ 2	2026-09-16 14:56:47 19 hours ago	S: 10.200.0.6 D: 192.168.10.50	ET EXPLOIT Possible CVE-2016-10033 PHPMailer RCE Attempt	app_proto:http hostname:10.85.4.10	Archive

5.png – 16/09/2026 14:56:47-17:36:37 – tentatives PHP puis ciblage répété des N1 (SNI). Capturé par : Thibault Foulon.

	#	Timestamp▼	Src / Dst	Signature	
▶	☆ 525	2026-09-17 09:39:22 a few seconds ago	S: 192.168.10.10 D: 192.168.10.30	MV GLOBAL sensitive service access	Archive 
	☆ 496	2026-09-16 19:01:44 15 hours ago	S: 10.200.0.6 D: 192.168.10.50	MV N1 TLS SNI shop.maisonverte.fr (E3, WordPress) app_proto:tls sni:shop.maisonverte.fr	Archive 
	☆ 50	2026-09-16 18:19:42 15 hours ago	S: 10.200.0.6 D: 192.168.10.50	SURICATA STREAM Packet with invalid timestamp app_proto:tls	Archive 
	☆ 118	2026-09-16 18:19:42 15 hours ago	S: 10.200.0.6 D: 192.168.10.50	TP LOCAL balayage de ports probable (SYN vers >15 ports en 10s)	Archive 
	☆ 142	2026-09-16 18:07:20 16 hours ago	S: 192.168.10.10 D: 192.168.10.50	MV GLOBAL sensitive service access app_proto:ssh	Archive 
	☆ 2	2026-09-16 18:05:39 16 hours ago	S: 10.200.0.6 D: 192.168.10.50	SURICATA STREAM CLOSEWAIT FIN out of window app_proto:tls	Archive 
	☆ 124	2026-09-16 18:01:07 16 hours ago	S: 192.168.10.10 D: 192.168.10.50	ET SCAN Potential SSH Scan OUTBOUND	Archive 
	☆ 47	2026-09-16 18:00:37 16 hours ago	S: 192.168.10.10 D: 192.168.10.50	ET SCAN Potential SSH Scan	Archive 
	☆ 256	2026-09-16 17:59:02 16 hours ago	S: 10.200.0.4 D: 192.168.10.50	MV N1 TLS SNI cache.maisonverte.fr (E2, reverse proxy) app_proto:tls sni:cache.maisonverte.fr	Archive 
	☆ 114	2026-09-16 17:49:08 16 hours ago	S: 10.200.0.5 D: 192.168.10.50	MV N1 TLS SNI vendeurs.maisonverte.fr (E5, Tomcat) app_proto:tls sni:vendeurs.maisonverte.fr	Archive 
	☆ 22	2026-09-16 17:46:57 16 hours ago	S: 10.200.0.5 D: 192.168.10.50	MV N1 TLS SNI cache.maisonverte.fr (E2, reverse proxy) app_proto:tls sni:cache.maisonverte.fr	Archive 
	☆ 624	2026-09-16 17:43:07 16 hours ago	S: 10.200.0.2 D: 192.168.10.50	MV N1 TLS SNI shop.maisonverte.fr (E3, WordPress) app_proto:tls sni:shop.maisonverte.fr	Archive 
	☆ 12	2026-09-16 17:36:52 16 hours ago	S: 10.200.0.5 D: 192.168.10.50	TP LOCAL balayage de ports probable (SYN vers >15 ports en 10s)	Archive 

6.png – 16/09/2026 17:36:52-18:19:42, et 17/09/2026 09:39:22 – scan SSH, accès à un service sensible, reprise le matin du Jour 4. Capturé par : Thibault Foulon.



7.png – vue d'ensemble EveBox : 10 095 alertes, 58 signatures, histogramme horaire (pic 14h30-14h49). Capturé par : Thibault Foulon.

Alert Categories No data	Alerting Protocols ⓘ No data										
Most Alerting Source Addresses No data	Least Alerting Source Addresses No data										
Most Alerting Destination Addresses <table><thead><tr><th>#</th><th>Address</th></tr></thead><tbody><tr><td>9368</td><td>192.168.10.50</td></tr><tr><td>635</td><td>192.168.10.30</td></tr><tr><td>56</td><td>10.85.4.10</td></tr><tr><td>36</td><td>192.168.10.10</td></tr></tbody></table>	#	Address	9368	192.168.10.50	635	192.168.10.30	56	10.85.4.10	36	192.168.10.10	Least Alerting Destination Addresses No data
#	Address										
9368	192.168.10.50										
635	192.168.10.30										
56	10.85.4.10										
36	192.168.10.10										

8.png – vue d'ensemble EveBox : adresses de destination les plus alertantes (192.168.10.50 : 9 368 hits ; 192.168.10.30 : 635 ; 10.85.4.10 : 56 ; 192.168.10.10 : 36). Capturé par : Thibault Foulon.

Aucune des 9 captures EveBox ci-dessus ne montre de signature spécifique aux pivots N2/N3 — seulement de la reconnaissance générique et les 3 N1. La sous-section suivante explique pourquoi, avec une source externe indépendante.

6a. Confirmation externe — Rapport d'attaque G10 → G04 (16/09/2026)

Le groupe attaquant assigné (G10) a communiqué son propre rapport d'attaque, daté du 16/09/2026. Il confirme, de son côté, la compromission réelle de 5 services — une source indépendante des captures EveBox du §6, à recouper avec elles :

SERVICE	EXPLOIT CONFIRMÉ CÔTÉ ATTAQUANT	SID APPLICABLE	VISIBLE PAR SURICATA ?
E2 (nginx, N1)	Traversal /files../ , flag lu	9000010 (contenu, TLS) / 9000026 (SNI)	Oui, via SNI (9000026, confirmé §5/§6) ; le contenu ne se voit pas (TLS, cf. §5)
E5 (Tomcat, N1)	PUT JSP root (CVE-2017-12615), exploit rejoué	9000012 (contenu, TLS) / 9000028 (SNI)	Oui, via SNI (9000028, confirmé §5/§6) ; le contenu ne se voit pas (TLS, cf. §5)
E7 (Elasticsearch, pivot)	RCE groovy root (CVE-2015-1427), exploit rejoué	9000013	Angle mort documenté §5 : trafic intra-Docker, hors du pont L2 nsm — seule une preuve ELK/log applicatif est possible, pas de preuve réseau attendue
E8 (Redis, pivot)	Débloqué par notre correctif de permission sur le flag ; commande MODULE	9000015	Même angle mort — preuve ELK/log applicatif uniquement
E11 (mongo-express, pivot)	RCE /checkValid (CVE-2019-10758), exploit rejoué	9000019	Même angle mort — preuve ELK/log applicatif uniquement

Le même rapport explique aussi, à l'inverse, pourquoi les autres pivots restent muets dans nos captures — pas une lacune de détection, mais des chaînes que l'attaquant n'a pas pu terminer avec son propre outillage : chaîne A bloquée après E8 (aucun client PostgreSQL disponible pour atteindre E10) ; chaîne B bloquée après E5 (le jenkins-cli.jar posé exige Java 11+, le Tomcat d'E5 n'a que Java 8 — E14 et E12 jamais atteints) ; chaîne C entièrement bloquée dès E3 (PHPMailer patché dans l'image WordPress déployée — E6, E9, E13 jamais atteints). C'est cohérent avec l'absence totale de signature E3/E6/E9/E12/E13/E14 dans nos 9 captures.

7 Corrélation réseau / logs — référentiel établi pendant le build

Ce tableau documente, pour chaque étape, où chercher la preuve réseau (Suricata/EveBox) et la preuve applicative (ELK). Les lignes E2/E3/E5 sont désormais couvertes des deux côtés : SID validé en auto-test (§5) puis ré-observé sur trafic attaquant réel en Phase 2 (§6).

ÉTAPE	SOURCE RÉSEAU	SOURCE LOG	STATUT
E2 fuite nginx (traversal)	Suricata/EveBox (SNID 9000026)	cache-dmz01	Auto-test 16/09 10:58:48 + ré-observée en Phase 2 (§6, 15h19-17h59) ; preuve applicative (/files../) à corréler côté ELK
E3 WordPress	Suricata/EveBox (SNID 9000027)	shop-dmz01	Auto-test 16/09 10:58:48 + ré-observée en Phase 2 (§6), signature la plus fréquente (3 562 hits) — service le plus scanné, mais exploitation confirmée non aboutie par le rapport d'attaque G10 (§6a) : PHPMailer patché dans l'image déployée, chaîne C bloquée dès ce maillon
E5 Tomcat PUT JSP	Suricata/EveBox (SNID 9000028)	market-dmz01	Auto-test 16/09 10:58:48 + ré-observée en Phase 2 (§6, 15h19-17h49) ; PUT JSP à confirmer côté ELK sur cette fenêtre
E7 Elasticsearch	Hors de portée du pont L2 nsm (angle mort documenté §5) — aucune alerte réseau attendue	search-srv01	Compromission confirmée par le rapport d'attaque G10 (§6a, RCE groovy root) ; preuve à obtenir côté ELK/log applicatif uniquement
E8 Redis	Hors de portée du pont L2 nsm (angle mort documenté §5) — aucune alerte réseau attendue	cache-srv01	Compromission confirmée par le rapport d'attaque G10 (§6a, commande MODULE, débloquée par le correctif de permission du flag) ; preuve à obtenir côté ELK/log applicatif uniquement
E10 PostgreSQL	Suricata si visible, sinon ELK	catalog-data01	Non atteint par G10 à ce jour (chaîne A bloquée après E8, faute de client PostgreSQL côté attaquant) — pas une lacune de détection
E14 Jenkins	Suricata si visible, sinon ELK	deploy-srv01	Non atteint par G10 (chaîne B bloquée après E5, jenkins-cli.jar incompatible Java 8) — pas une lacune de détection
E12 XXL-JOB	Suricata si visible, sinon ELK	pos-consol-shops01	Non atteint par G10 (même blocage chaîne B) — pas une lacune de détection
E11 Mongo Express	Hors de portée du pont L2 nsm (angle mort documenté §5) — aucune alerte réseau attendue	clients-data01	Compromission confirmée par le rapport d'attaque G10 (§6a, RCE /checkValid) ; preuve à obtenir côté ELK/log applicatif uniquement
E6 OFBiz	Suricata si visible, sinon ELK	backoffice-srv01	Non atteint par G10 (chaîne C entièrement bloquée dès E3) — pas une lacune de détection
E9 Samba	Suricata si visible, sinon ELK	files-srv01	Non atteint par G10 (même blocage chaîne C) — pas une lacune de détection
E13 Struts2	Suricata si visible, sinon ELK	wms-shops01	Non atteint par G10 (même blocage chaîne C) — pas une lacune de détection

Requêtes Kibana identifiées pour documenter la corrélation applicative (à exécuter et capturer une fois une attaque réelle observée) :

```
container.name:"cache-dmz01"
container.name:"market-dmz01" AND message:"PUT"
message:"AI-CANARY"
container.name:"deploy-srv01"
container.name:"pos-consol-shops01"
```

8 Prompts utilisés pour la génération des règles

Les 23 règles du groupe (SID 9000007-9000029) ont été produites avec l'assistance de **Claude Code** (Claude Sonnet 5, Anthropic), sur le poste de Yanis Hortholary, en deux sessions le 16/09/2026. Preuve vérifiable : les deux commits qui introduisent ces règles portent la co-signature Co-Authored-By: Claude Sonnet 5 <noreply@anthropic.com> .

COMMIT	SID COUVERTS	TÂCHE DEMANDÉE À L'ASSISTANT (RÉSUMÉ DU MESSAGE DE COMMIT)
8d5f426	9000007-9000025	

		Écrire et déployer 19 règles Suricata spécifiques au groupe (reconnaissance, N1 E2/E3/E5, pivots E6-E14, DATA E10, canary IA, isolation), au-dessus des 6 règles socle de la plateforme ; valider avec <code>suricata -T</code> et recharger.
a796476	9000026-9000029	Ajouter 4 règles SNI TLS après avoir constaté en test réel que les règles de contenu HTTP précédentes ne se déclenchaient jamais sur le trafic TLS d'E2/E3/E5 ; confirmer leur déclenchement réel dans <code>fast.log</code> et synchroniser <code>tp-local.rules</code> dans le dépôt.

Le texte exact des échanges (prompts mot pour mot) de ces deux sessions n'a pas été conservé séparément du dépôt — seul l'historique git fait foi. Les demandes ci-dessus sont un résumé fidèle de ce que documentent les messages de commit, pas une reconstruction inventée. Aucun autre SID (socle 9000001-9000006, écrits par la plateforme, ni les règles du 17/09 s'il y en a) n'est concerné par une assistance IA à ce jour.

9

Répartition nominative — qui a rédigé quelle règle / quelle capture

MEMBRE	CONTRIBUTION DÉTECTION	RÈGLE(S) / CHAPITRE / CAPTURE
Yanis Hortholary	Écriture et déploiement des 23 règles locales (avec assistance Claude Code, voir §8), diagnostic et correction de la règle NAT WAN → E2 sur OPNsense (avec Thibault Foulon — condition nécessaire pour observer du trafic N1 réel), rédaction de l'ensemble de la documentation de détection	SID 9000007-9000029, 05-detection.md, 08-regles-suricata.md, présent rapport
Nathan Palvadeau	Surveillance EveBox le 16/09 (Jour 3), analyse des alertes/logs EveBox et du trafic réseau capturé, activation/rechargement des règles sur la sonde <code>nsm</code>	<code>configure-suricata-notes.sh</code> , règles socle
Thibault Foulon	Réalisation des 9 captures EveBox du rapport (§5 : <code>image.png</code> , <code>1.png</code> ; §6 : <code>2.png</code> à <code>8.png</code>), surveillance en cours le 17/09 (Jour 4), diagnostic de la règle NAT WAN → E2 sur OPNsense (avec Yanis Hortholary) et vérification de la configuration OPNsense sous-jacente	06-recette.md, §5-6 du présent rapport
Damien Aouaj, Adam Attafi, Seymen Isikli	Non affectés à la détection sur cette phase — rôle attaquant Phase 2 / autre chapitre	—

Attribution des captures confirmée par le groupe. Reste à confirmer, pour la ligne 17/09 09:39 du §6 (encore *en cours*), qui complètera la capture finale une fois la fenêtre Phase 2 close.

10

Reste à faire avant la remise

- Récupérer, via ELK/Filebeat, la preuve applicative des 3 pivots confirmés compromis par le rapport G10 (E7, E8, E11 — §6a) : Suricata ne peut structurellement pas les voir (angle mort intra-Docker), donc leur seule preuve possible est le log applicatif du conteneur (`search-srv01`, `cache-srv01`, `clients-data01`).
- Continuer à surveiller EveBox jusqu'à la fin de la fenêtre Phase 2 (Jour 4, 18h00) et compléter la dernière ligne du §6 (17/09 09:39, encore *en cours*).
- E10, E14, E12, E6, E9, E13 restent sans preuve d'attaque — cohérent avec les 3 chaînes signalées bloquées par G10 (§6a), pas une lacune de détection ; à ne réviser que si un rejeu ultérieur de l'attaquant les atteint avant 18h00.